

SRS PHASE 2 · IDENTITY PROTECTION

# Identity Protection Platform

## Cornell Deep School

- v2 — school portal RBAC, digital forensics, account recovery, authentication benchmark
  - A 0–100 risk score for every login attempt with explained reasons
  - 140 automated checks green: smoke 17 · e2e 77 · ui-smoke 28 · restart 18
-

The problem

# “Password only” is not enough

- Passwords get stolen or guessed
  - How do we tell a legitimate login from a suspicious one before damage happens?
  - Solution: an instant contextual assessment of every sign-in attempt
-

Risk engine

# A live risk score for every attempt

- $F\_TIME\_ANOMALY + 15 \cdot F\_NEW\_IP + 25 \cdot F\_NEW\_DEVICE + 30 \cdot F\_IMPOSSIBLE\_TRAVEL + 40 \cdot F\_BLACKLISTED\_IP + 45$
  - LOW 0–30 → direct login · MEDIUM 31–69 → cross-device approval · HIGH 70–100 → instant lockdown
  - Every decision is recorded in a detailed audit log and broadcast live
-

SRS scenarios

## Three strict levels

- S1: password only at LOW risk
  - S2: password + OTP code (RFC 6238)
  - S3: OTP + e-mail + RBAC — and the operations console is admin-only
-

Trusted device

# From “an e-mail arrives” to “a trusted device”

- Registration + real e-mail verification (Ethereal)
  - Clicking the verification link stamps this browser as Trusted (encrypted 1-year cookie)
  - Devices revocable from the Security Center
-

v2 · School portal

## Strict RBAC across 3 roles

- 8 modules × 3 roles (courses/grades/assignments/attendance/rosters/user directory)
  - Student: denied rosters, directory and matrix (403)
  - Admin: every module + the permission matrix on screen
-

v2 · Security

# Account recovery + MFA reset

- request → reset → validate — a 6-digit verification code
  - TOTP rotation + new password + 10 single-use recovery codes
  - Every step is recorded in the audit log
-

v2 · Investigation & performance

# Forensics + Benchmark

- Reconstructing chronological timelines per user/IP/device/outcome
  - Cases capture evidence automatically with Markdown export for archiving
  - Scenario comparison with real login times (elapsed\_ms)
-

SOC dashboard

# A live operations room

- Overview · Audit · Sessions · Trusted Devices · Factors · Blacklist · Attack Sim
  - SSE streaming: login events and alerts arrive instantly
  - Simulated attacks A (brute force) · B (impossible travel) · C (credential stuffing)
-

## Results

# Comprehensive testing — every stage is green

- 140 automated checks on a pristine database
  - e2e 77 covers portal/recovery/forensics/benchmark + data resilience after restart
  - demo.mp4 records every feature while running
-

Future directions

# What would a production rollout look like?

- Extra factors: face/device biometrics and real geo-location risk
  - Machine learning over each user's login habits
  - Automatic isolation, monitoring-platform alerts and threat sharing
-

Thank you

# AuthShield 360

- Run it: npm start then localhost:4000
  - Deliverables: dist/AuthShield360-v2.zip · docs/ · demo.mp4
-